

End to End Compliance Risk Management

JUNE 2020



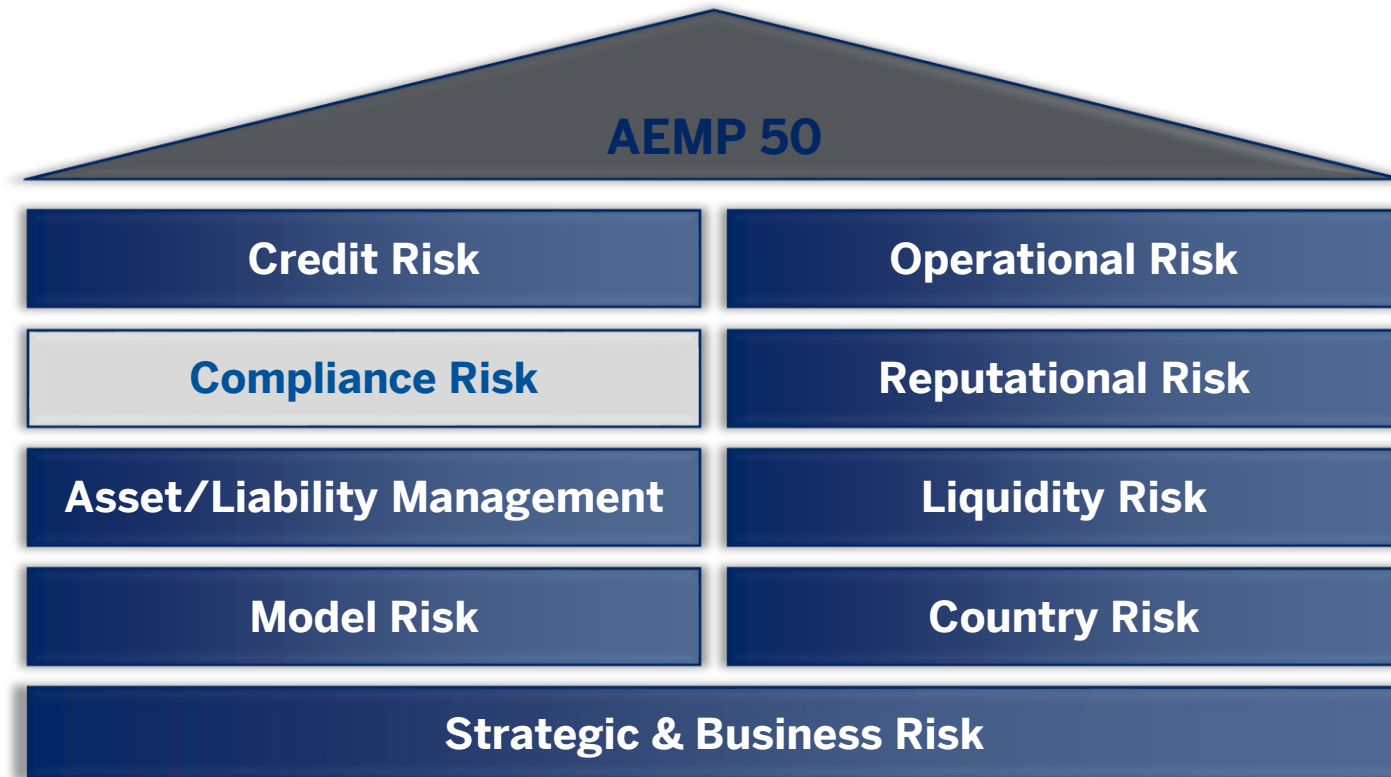
Global Risk and
Compliance

It all starts with Enterprise Risk
Management - Our Policies and Risk
Appetite...



Enterprise-Wide Risk Management Policy (AEMP 50)

The Enterprise-Wide Risk Management Policy (AEMP 50) establishes our enterprise risk management program and provides principles and executional guidance for the development and maintenance of a framework for identifying, measuring and reporting risks across these categories:



Compliance Risk Appetite Statement

The Enterprise-Wide Risk Management Policy (AEMP 50) includes Risk Appetite Statements for each category of risk. Below is the risk appetite statement for Compliance Risk:

Compliance Risk Appetite Statement

- *American Express aims to meet or exceed regulatory requirements and expectations.*
- *The Company views its ability to effectively mitigate compliance risk as an important aspect of its business model and integral to its identity as a good corporate citizen, a sound financial holding company, and a respected consumer brand.*
- *The Company seeks to manage and mitigate compliance risk by assessing, controlling, monitoring, measuring and reporting the regulatory risks to which it is exposed.*
- *The Company will pursue with appropriate urgency the cessation of compliance lapses, particularly those impacting our customers.*
- *The Company strives to be regarded as value-oriented and even-handed by our customers, healthy by our shareholders, and competent and trustworthy by our regulators.*



Our Compliance Risk Management Policy
and framework are codified in AEMP 39...



Global Compliance Risk Management Policy (AEMP 39)



AEMP 39 Defines the Scope of Compliance

The following categories are the responsibility of Global Compliance & Ethics and are codified in AEMP 39:

- ✓ **Anti-Corruption**
- ✓ **Anti-Money Laundering**
- ✓ **Privacy**
- ✓ **Consumer Protection and Business Practices (including credit-related protection)**
- ✓ **E-Banking and E-Commerce**
- ✓ **Fair Lending**
- ✓ **Licensing (related to issuance/operation of AXP products or services)**
- ✓ **Outsourcing and Vendor Management**
- ✓ **Sanctions**
- ✓ **Proprietary Trading**
- ✓ **Other banking Law(s) and/or Regulation(s) related to AXP's status as a Bank Holding Company**

The Global Compliance Program is how
we execute on our policy and regulatory
obligations...



Three Lines of Defense Model

The AXP Compliance Risk Management System leverages a “**three lines of defense**” model to organize and execute compliance-related control activities.

1st

Business Unit Ownership

- ✓ Implement controls to meet the obligations of applicable legal requirements
 - ✓ Perform 1st line testing of controls (e.g., Regulatory Business Self-Testing)
 - ✓ Remediate issues, as necessary
-

2nd

Compliance Oversight

- ✓ Advise and assess quality of 1st line controls
 - ✓ Monitor and validate results of Regulatory Business Self-Testing
 - ✓ Perform independent 2nd line testing
 - ✓ Oversee issue remediation
-

3rd

Internal Audit Assurance

- ✓ Perform 3rd line independent reviews which include:
 - Business Unit controls
 - Compliance Risk Assessments, Monitoring, Testing, Regulatory Compliance Training

What Compliance Must Do

A robust Compliance Risk Management Program ensures that we:



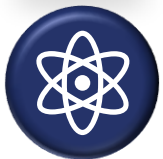
Understand the laws and related regulations we have to follow



Follow these laws and related regulations through multi-level monitoring, assessments, testing, and reporting activities



Handle lapses appropriately



Promote awareness of key legal requirements to ensure employees, contractors and other relevant third parties have a general understanding of key principles of applicable legal requirements and who to turn to for more information and for assistance as needed.

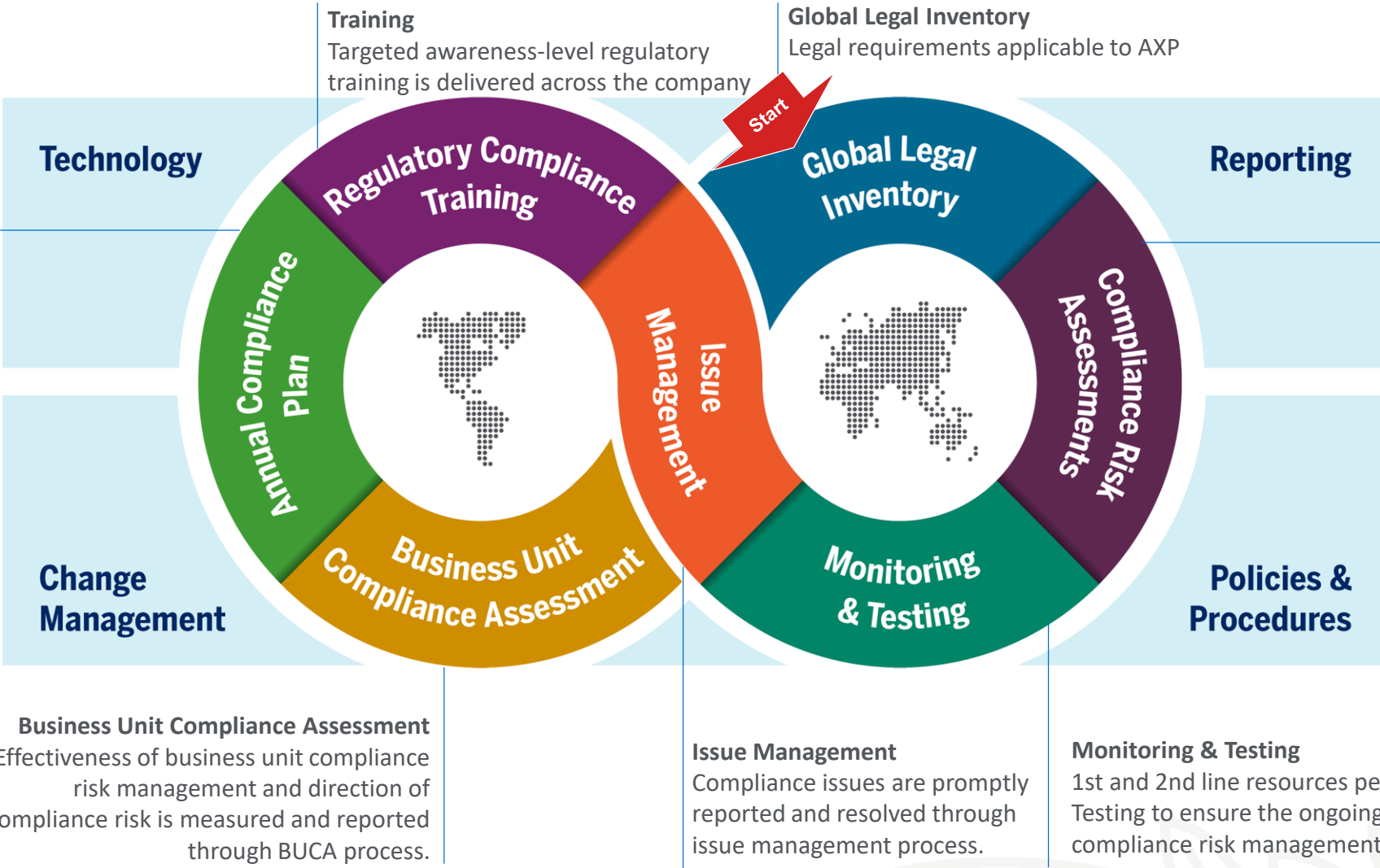
Compliance Requirements – Based Approach

Compliance employs a requirements based approach which facilitates the identification and documentation of applicable laws and regulations, the assessment of process and controls in meeting those obligations and, where and when necessary, the identification and tracking of actions to enhance the control environment.



Compliance Risk Management Program Overview

The ongoing execution and evolution of the Compliance Risk Management Program ensures a strong and sustainable program across the Company, including AENB.



An Example of How the Program Works – Privacy and Electronic Communications (EC Directive) Regulations 2003



Global Legal Inventory

The **Global Legal Inventory** is a collection of applicable U.S. Federal, U.S. State and International legal and regulatory requirements by area of law as defined in the Company's Compliance Policy (AEMP 39).



Example used for illustrative purposes

- 1 GCO identifies and certifies **Privacy and Electronic Communications Regulations 2003** is in scope for products, services and legal entities
- 2 **Privacy and Electronic Communication Regulations 2003** are assigned to applicable Business Units
 - i. *A person shall neither transmit, nor instigate the transmission of, a communication for the purposes of **direct marketing by means of electronic mail**-- (a) where the identity of the person on whose behalf the communication has been sent has been disguised or concealed; (b) where a valid address to which the recipient of the communication may send a request that such communications cease has not been provided; (c) where that electronic mail would contravene regulation 7 of the Electronic Commerce (EC Directive) Regulations 2002; or (d) where that electronic mail encourages recipients to visit websites which contravene that regulation.*

Business Units in Scope

- ✓ Global Commercial Services
- ✓ Corporate Affairs & Communications
- ✓ Credit & Fraud Risk
- ✓ **Enterprise Digital Analytics**
- ✓ Global Risk Banking & Compliance
- ✓ Global Services
- ✓ International Consumer Services
- ✓ US Consumer Products & Services

Compliance Risk Assessment

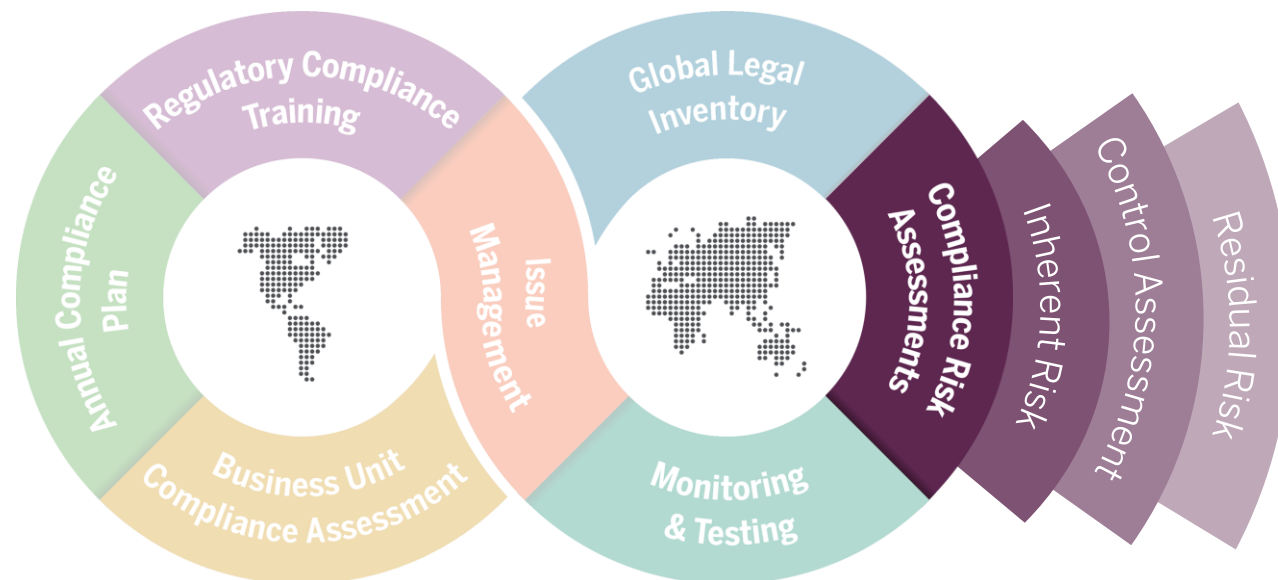
Compliance Risk Assessments of American Express' products/services, legal entities, and businesses provide an overall view of the compliance risks to which the Company is exposed and the strength of its control environment. The Compliance Risk Assessment process helps to ensure compliance risks are managed effectively.

3 Compliance Officers **assign legal requirements to processes** with the business unit

- ✓ **Business Unit:** *Enterprise Digital Analytics*
- ✓ **Legal Requirement:** A person shall neither transmit, nor instigate the transmission of, a communication for the purposes of direct marketing by means of electronic mail-- (a) where the identity of the person on whose behalf the communication has been sent has been disguised or concealed; . . . (b) where a valid address to which the recipient of the communication may send a request that such communications cease has not been provided; (c) where that electronic mail would contravene regulation 7 of the Electronic Commerce (EC Directive) Regulations
- ✓ **Business Process:** *Push Notification, SMS, and Email Management*

4 The business **identifies the controls** to mitigate the risk posed by the legal requirement

- i. *Customer Privacy and Opt in / Opt Out Preferences*
 - i. *Manual Key Control, Preventive and Transactional*
 - ii. *Quality of Control Rating = Adequate*
 - iii. *Control Conclusion = Effective*
- iv. *Push Notification Opt In / Opt Out and CM Consent in Mobile App*
 - i. *Manual Key Control, Preventive and Transactional*
 - ii. *Quality of Control Rating = Adequate*
 - iii. *Control Conclusion = Effective*
- v. *Monitoring Process*
 - i. *Automated Non Key Control, Preventive and Ad Hoc*
 - ii. *Quality of Control Rating = Adequate*
 - iii. *Control Conclusion = Effective*

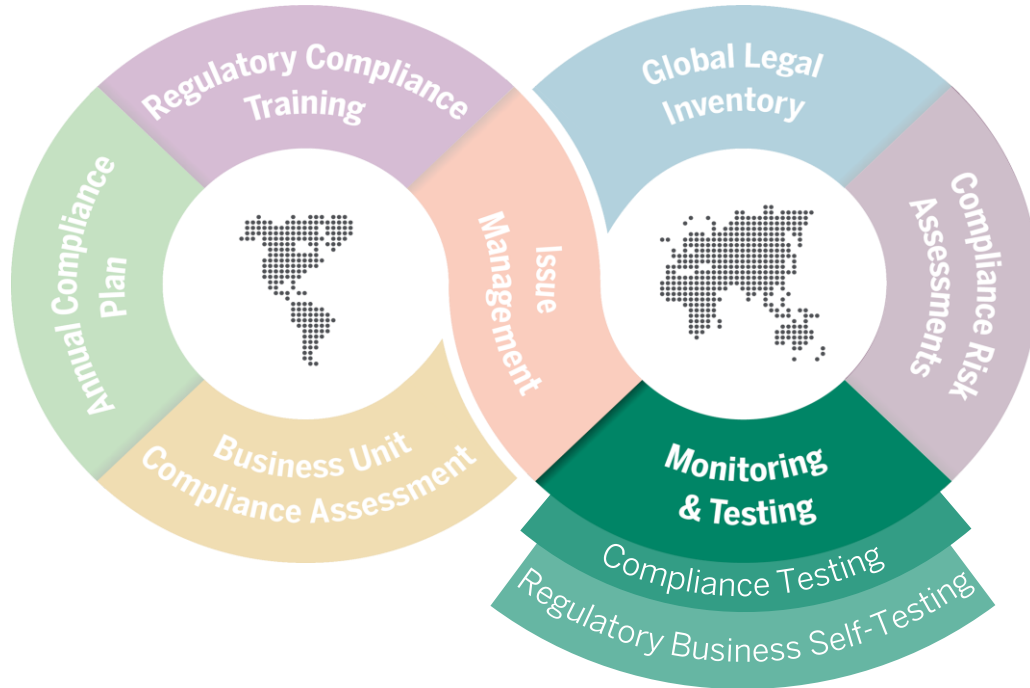


5 Collection of **processes and controls** are assessed for adequacy

- ✓ *Privacy and Electronic Communications inherent risk to the company is High*
- ✓ *Quality of Risk Management looks at the overall control environment for this process / requirement combination and came is as Adequate*
- ✓ *Residual Risk Rating Result is Medium*

Monitoring & Testing

Compliance Monitoring and Compliance Testing helps ensure the ongoing effectiveness of compliance risk management.



6 1st and 2nd line resources perform **monitoring and testing** to ensure ongoing effectiveness of Privacy and Electronic Communications processes and controls

- ✓ **Business Unit:** Enterprise Digital Analytics
- ✓ **Legal Requirement:** A person shall neither transmit, nor instigate the transmission of, a communication for the purposes of direct marketing by means of electronic mail-- (a) where the identity of the person on whose behalf the communication has been sent has been disguised or concealed; . . . (b) where a valid address to which the recipient of the communication may send a request that such communications cease has not been provided; (c) where that electronic mail would contravene regulation 7 of the Electronic Commerce (EC Directive) Regulations
- ✓ **Business Process:** Push Notification, SMS, and Email Management
- ✓ **Mitigating Control:** Customer Privacy and Opt in / Opt Out Preferences
- ✓ **Mitigating Control:** Push Notification Opt In / Opt Out and CM Consent in Mobile App
- ✓ **Mitigating Control:** Monitoring Process

1st Line: Regulatory Business Self Testing (RBST)

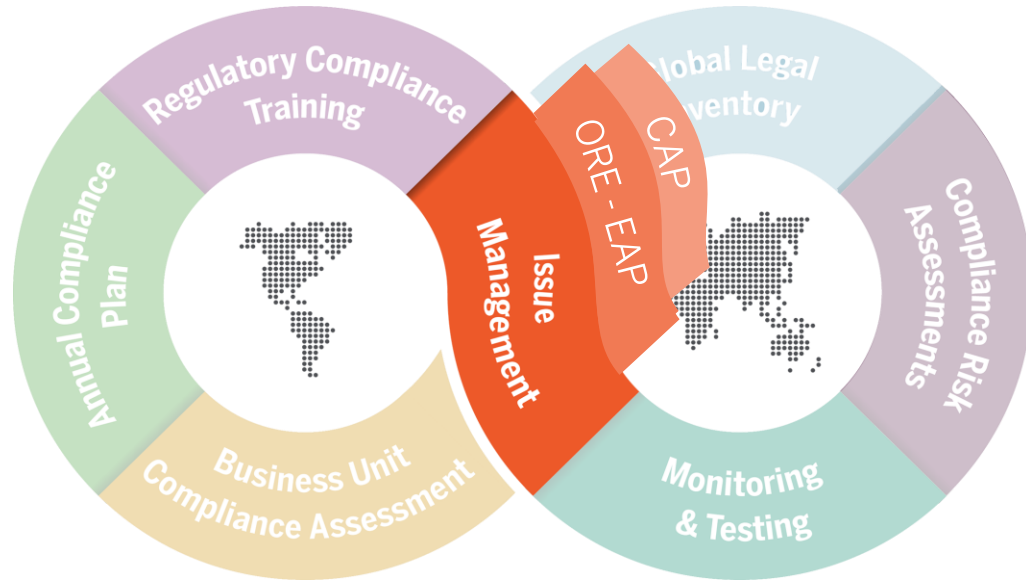
- ✓ **Test Description:** Confirm there is a process in place to update customer privacy choices
- ✓ **Tested:** Quarterly
- ✓ **Test Result:** Pass

2nd Line: Second Line Compliance Testing (SLCT)

- ✓ **Test Description:** Assessment of effectiveness of execution and decision making in servicing and marketing emails
- ✓ **Tested:** Annually
- ✓ **Test result:** In progress 2020

Issue Management

Compliance Issue Management enables AXP and its subsidiaries to promptly report & resolve compliance issues, including those that may impact Customers. The Compliance Issue Management Policy defines and establishes the baseline requirements for reporting and resolving compliance issues across the Company

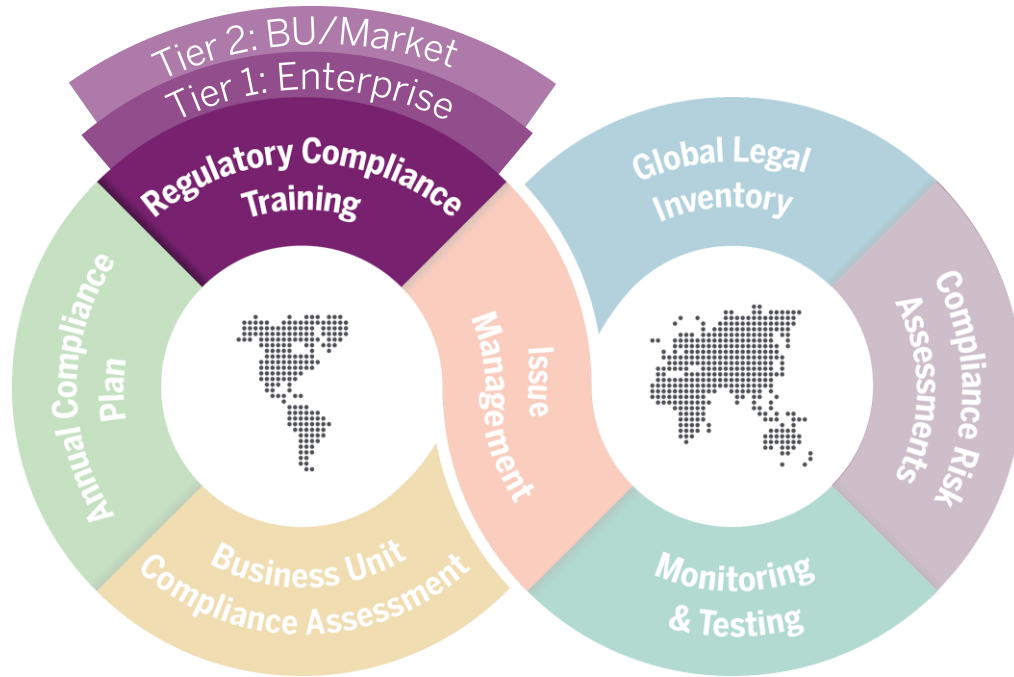


7 Privacy and Communication Regulation issues are identified via Monitoring, Testing, Risk Assessment, Complaints and in the course of business. As identified, they are promptly reported and resolved through issue management process

- ✓ **Issue Management Examples:**
 - ✓ Enterprise Digital and Analytics team scrubbing process missed an existing account resulting in a telesales agent being given data for an existing customer that had opted out for marketing

Regulatory Compliance Training

Regulatory Compliance Training consists of two tiers to enable effective delivery of targeted awareness-level regulatory training across the company

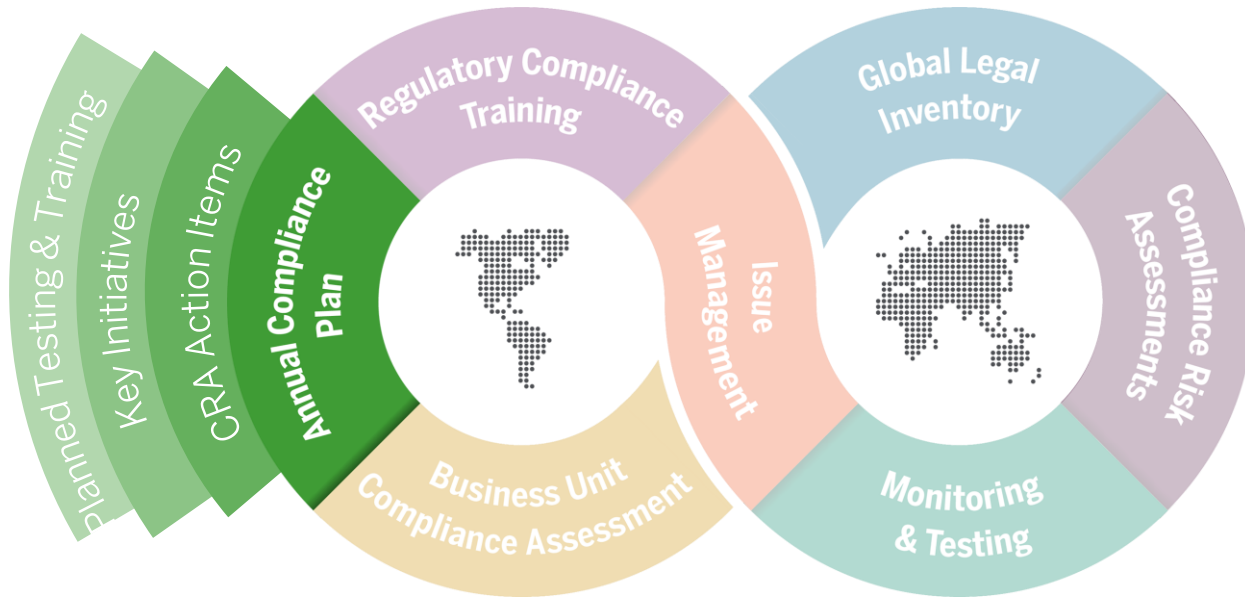


8 Enterprise Essential Tier II Training for **Privacy** is assigned based on regulation applicability and performance in Business Units

- ✓ *Business Unit: Enterprise Digital and Analytics*
- ✓ *Curriculum: Privacy Training*

Annual Compliance Plan

Annual Compliance Plans leverage results of Compliance Risk Assessments, Business Unit Compliance Assessments, Compliance Monitoring and Testing, Compliance Issue Management, Regulatory Compliance Training, and other compliance-related information to set priorities for the allocation of resources for the coming year.



- 9 Subject Matter Experts such as LOBCO, MCO and Privacy teams review material to determine if **Privacy and Communication Regulations** are required

- ✓ **Regulation:** Privacy and Electronic Communications Regulations
- ✓ **ACP Goal:** Complete Privacy and Electronic Communications Regulations action items identified from the CRA

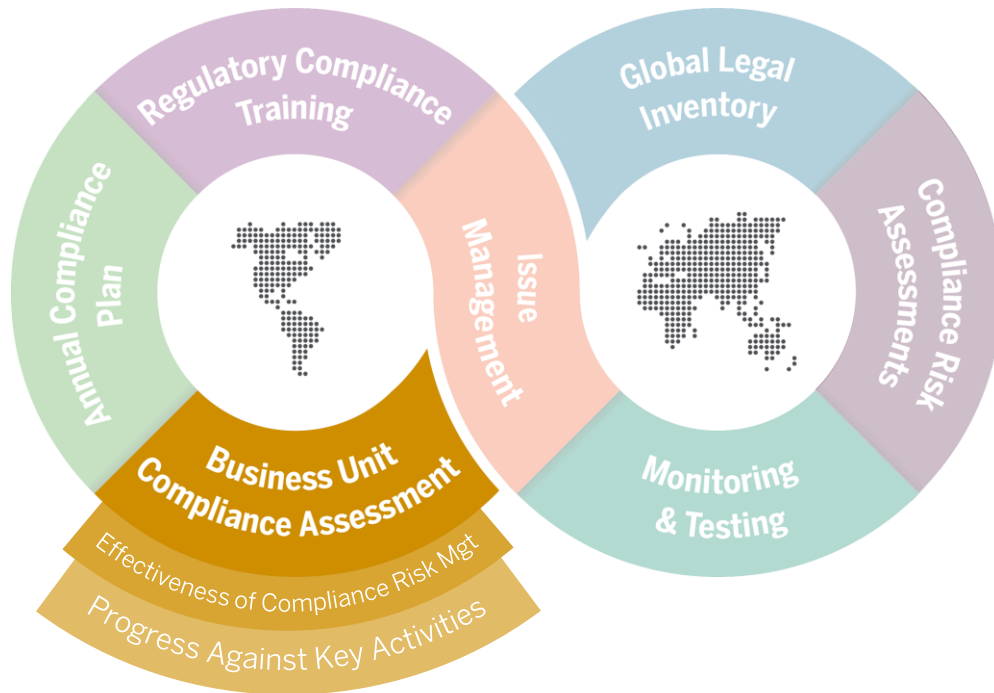
Action Item examples:

- ✓ Controls Not Documented (OC1)
- ✓ Unknown control performance/control hasn't been tested (OC2)
- ✓ Missing PnP (GOV1)
- ✓ Weak PnP and weak control or unknown control (GOV2)
- ✓ Adequate PnP with weak control and high people risk (GOV3)

NOTE: End to end example did not have action items assigned as a result of the Adequate Risk Assessment ratings

Business Unit Compliance Assessment

The **Business Unit Compliance Assessment (BUCA)** provides a standardized approach for measuring and reporting on the effectiveness of business unit compliance risk management and progress against compliance activities.



- 10 Effectiveness of business unit with **Privacy and Communication Regulations** in scope is measured and reported in the Control and Compliance Rating

- ✓ **Business Unit:** Enterprise Digital and Analytics
- ✓ **Progress/ACP Rating:** Satisfactory – although action item's aren't applicable for this scenario, rating would remain satisfactory

Action Item examples:

- ✓ Controls not documented (OC1)
- ✓ Unknown control performance/control hasn't been tested (OC2)
- ✓ Missing PnP (GOV1)
- ✓ Weak PnP and weak control or unknown control (GOV2)
- ✓ Adequate PnP with weak control and high people risk (GOV3)

NOTE: End to end example did not have action items assigned as a result of the Adequate Risk Assessment ratings

Compliance Risk Management Supporting Program Elements

Program Elements are integrated with eGRC strategy on the Archer platform for execution

Reporting provides information to Compliance Officers of key activities and business unit performance



Change Management ensures changes to Laws, Regulations, Processes, Controls and Products are managed throughout the program elements.

Policies and Procedures define and document the Program Element processes